Que funcione es el comienzo

Calidad de código, deuda técnica y seguridad · DevSecOps

Nuestra propuesta

- Comprobar comportamiento
- Revisar calidad y seguridad
- Controlar antes de integrar

Una demo pequeña

- Notas de alumnos en Python
- GitHub Actions + SonarCloud
- Dependabot + protección de main

¿Qué hace la aplicación?

Un módulo Python; los datos entran como una lista de alumnos

Tres funciones

- Buscar alumnos por materia
- Aprobar con nota ≥ 6
- Resumir cantidad, promedio y mejor nota

Un ejemplo concreto

- Ana: 8 · Bruno: 4 · Carla: 9
- Aprobados: Ana y Carla
- Promedio del curso: 7,0

La deuda aparece al mantener

Una solución rápida puede aumentar el costo del próximo cambio

Deuda técnica

- Copiamos el cálculo de un reporte
- Una corrección requiere cambiar dos sitios
- Más trabajo y riesgo de inconsistencias

Code Smells

- Variables que nunca se usan
- Funciones difíciles de entender
- Señales para revisar la mantenibilidad

Dos formas de revisar el código

Los tests y el análisis estático responden preguntas diferentes

Testing dinámico

- Ejecuta el código
- Compara resultados con lo esperado
- pytest aquí; Playwright en navegador

Análisis estático · SAST

- Inspecciona sin ejecutar la aplicación
- Busca patrones de errores y seguridad
- SonarCloud analiza nuestro cambio

También dependemos de código ajeno

La cadena de suministro incluye librerías y herramientas del CI

Qué puede pasar

- Una versión tiene una vulnerabilidad
- Una cuenta de publicación es comprometida
- Un paquete malicioso llega al proyecto

Dependabot

- Detecta versiones con avisos conocidos
- Genera alertas y propone actualizaciones
- Ya tenemos el PR #1 de python-multipart

Qué tenemos y qué falta

Estado consultado el 13/10/2026 · comprobar antes de grabar

Ya funciona

- Tests y reportes de cobertura
- SonarCloud dentro del workflow
- PR #2 rojo y PR #1 de Dependabot

Por completar

- Verificar bloqueo real de merge
- Corregir y comprobar checks verdes
- Grabar evidencia y ensayar

Qué recorre cada Pull Request

GitHub Actions ejecuta la secuencia automáticamente

PR › Instalar › Tests + cobertura › SonarCloud › Gate › Merge*

Quality Gate

- Bugs nuevos = 0
- Vulnerabilidades nuevas = 0
- Cobertura nueva ≥ 80%

*Checks obligatorios

- GitHub debe exigir su aprobación
- Gate rojo → check rojo → bloqueo
- Otras condiciones también se cumplen

Leer el dashboard

Comparar el código global con el código nuevo del PR

Problemas detectados

- Bugs → confiabilidad
- Vulnerabilidades → seguridad
- Code Smells → mantenibilidad

Otras métricas

- Duplicación → bloques repetidos
- Cobertura → código ejecutado en tests
- 100% no prueba todos los escenarios

La demo roja ya está preparada

PR #2 · Agrego reporte de aprobados

Qué ocurre

- Se copia el cálculo del reporte
- Los tests antiguos siguen pasando
- La función nueva casi no se ejecuta

Resultado comprobado

- Cobertura nueva: 4,8% < 80%
- Duplicación: 82,8% > 3%
- Quality Gate: ERROR

Agregar captura real: gate rojo + checks + merge bloqueado

La corrección cabe en tres líneas

Filtrar los aprobados y reutilizar el reporte existente

```
def reporte_aprobados(alumnos):
    aprobados = [a for a in alumnos if esta_aprobado(a)]
    return reporte_curso(aprobados)
```

Qué mejora

- Un solo cálculo para mantener
- Sin la variable que no se usa
- Mismo objetivo funcional

Qué pruebo

- Ana y Carla: promedio 8,5
- Sin aprobados: reporte vacío
- Una nota de 6 también aprueba

Cerrar el ciclo con evidencia

El resultado verde debe comprobarse después del nuevo push

En GitHub y SonarCloud

- Mismo PR, nuevo commit
- Tests y gate aprobados
- Merge permitido al cumplir requisitos

En Dependabot

- Mostrar la alerta de seguridad
- Mostrar la versión propuesta en PR #1
- Revisar checks antes de integrar

Agregar captura real del nuevo análisis verde y del PR de Dependabot

Cada control responde una pregunta

Automatizar la revisión para integrar mejores cambios

Antes de integrar

- Tests: ¿se comporta como esperamos?
- SonarCloud: ¿cumple calidad y seguridad?
- Dependabot: ¿hay versiones vulnerables?

Lo que demostramos

- El rojo tiene un motivo concreto
- La corrección mejora código y tests
- GitHub exige los checks configurados